



AN TOÀN CƠ SỞ DỮ LIỆU

Chương 1: Tổng quan



Nguyễn Duy Phúc

duyphucit@live.com

Vĩnh Long, 09/2025

Nội dung

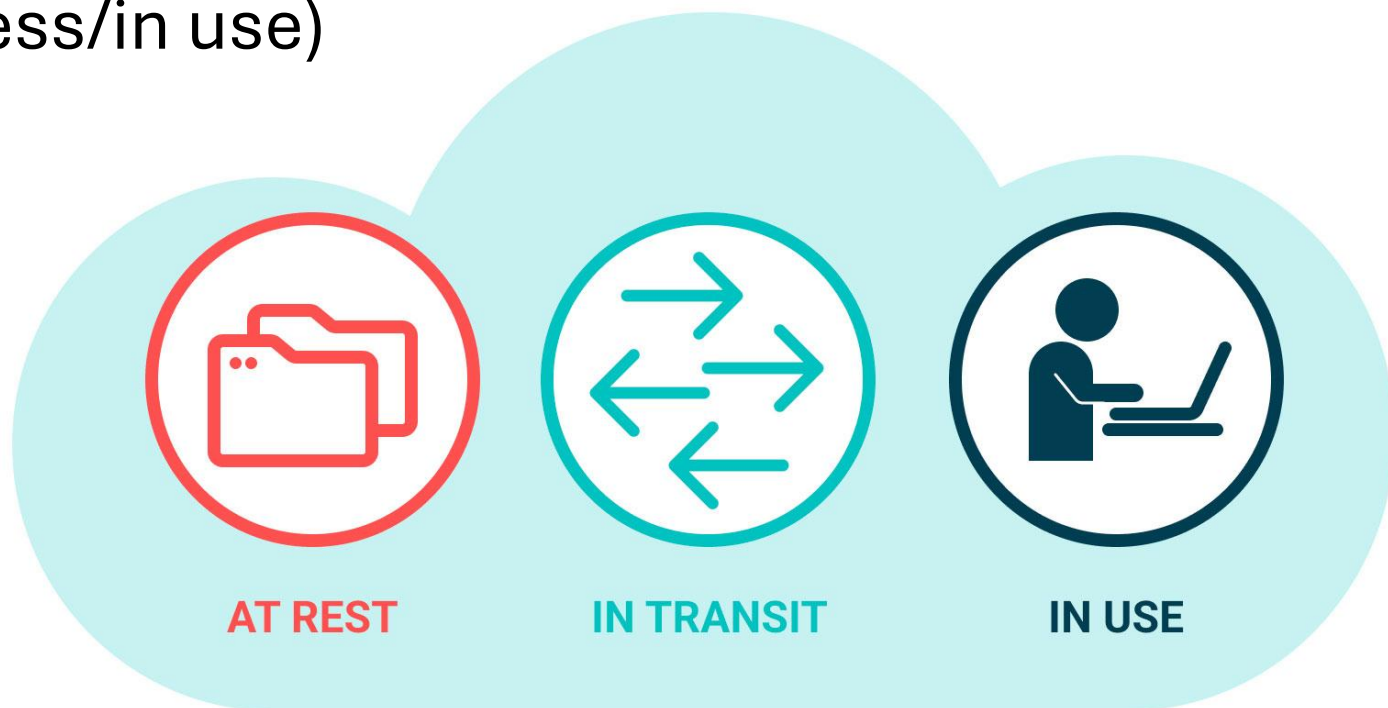


- ❑ Khái niệm bảo mật thông tin, các nguyên tắc cốt lõi của an toàn thông tin
- ❑ Các mối đe dọa an ninh
- ❑ Các biện pháp bảo mật và các yêu cầu an ninh
- ❑ Khái niệm bảo mật cơ sở dữ liệu, phân biệt với bảo mật thông tin

Bảo mật thông tin (Information Security)



- ❑ Là việc bảo vệ dữ liệu ở mọi hình thức (số hóa hoặc phi số hóa) trong tất cả các trạng thái:
 - Lưu trữ (at rest)
 - Đang xử lý/ sử dụng (in process/in use)
 - Truyền tải (in transit)

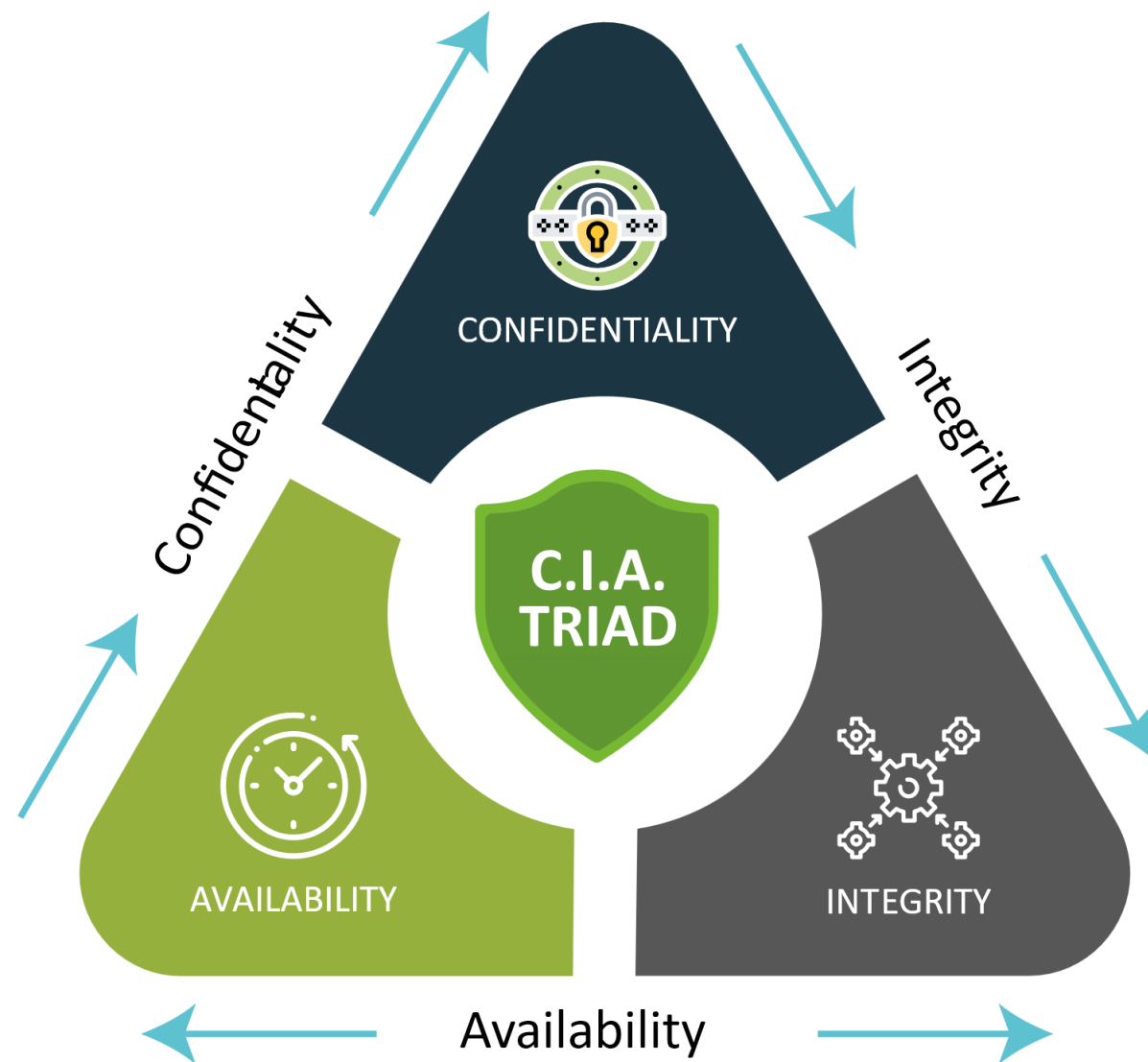


Bảo mật thông tin (tt)



C.I.A Triad

- ▣ Bộ 3 mục tiêu cốt lõi của An toàn thông tin
 - Confidentiality (Bí mật)
 - Integrity (Toàn vẹn)
 - Availability (Khả dụng)



Bảo mật thông tin (tt)



Tính bí mật (Confidentiality)

- ❑ Đảm bảo thông tin chỉ được truy cập bởi những tác nhân được phép (người dùng, ứng dụng, dịch vụ)
- ❑ Ví dụ:
 - Người dùng chỉ có thể xem tài khoản ngân hàng của mình, không phải của người khác
 - Dữ liệu truyền trên mạng được mã hóa để tránh nghe lén

Bảo mật thông tin (tt)



Tính toàn vẹn (Integrity)

- ❑ Bảo vệ thông tin khỏi việc bị sửa đổi, thêm, xóa trái phép
- ❑ Đảm bảo thông tin luôn chính xác (accurate), đầy đủ (complete), và nhất quán (consistent)
- ❑ Ví dụ:
 - Một bảng tính tài chính bị thay đổi con số → gây ra báo cáo sai lệch
 - Nếu một giá trị bị thay đổi, các giá trị tổng hoặc trung bình liên quan cũng phải thay đổi theo để duy trì tính nhất quán

Bảo mật thông tin (tt)



Tính khả dụng (Availability)

- Đảm bảo người dùng hợp lệ có thể truy cập thông tin đúng lúc, kịp thời
- Ví dụ:
 - Hệ thống ngân hàng phải cho phép khách hàng truy cập tài khoản bất cứ khi nào cần
 - Nếu máy chủ bị tấn công DoS/DDoS → người dùng hợp lệ không thể truy cập dịch vụ.

Các mối đe dọa an ninh, biện pháp kiểm soát và các yêu cầu



Các mối đe dọa an ninh (Security threats)

- ❑ Người dùng, chương trình hoặc dịch vụ có thể ảnh hưởng/xâm phạm tính C.I.A của hệ thống
- ❑ Phân loại
 - *External Threats* (mối đe dọa bên ngoài): tác nhân không thuộc tổ chức. Ví dụ: Hacker tấn công hệ thống email để lấy dữ liệu
 - *Internal Threats* (mối đe dọa bên trong): đến từ chính người hoặc hệ thống có liên quan trong tổ chức. Thường nguy hiểm hơn vì có hiểu biết về hệ thống hoặc có quyền hạn nhất định. Ví dụ: Nhân viên có quyền xem dữ liệu tài chính nhưng cố tình truy cập dữ liệu nhân sự

Các mối đe dọa an ninh, biện pháp kiểm soát và các yêu cầu (tt)



Kiểm soát an ninh (Security Controls)

- ❑ Các cơ chế hoặc công cụ được triển khai để ngăn chặn, phát hiện, giảm thiểu mối đe dọa
- ❑ Ví dụ theo nguyên tắc CIA:
 - Confidentiality: mã hóa dữ liệu, xác thực 2 yếu tố, thẻ từ/USB token
 - Integrity: hash, checksum, chữ ký số để phát hiện sửa đổi
 - Availability:
 - Sao lưu & khôi phục dữ liệu
 - RAID, hệ thống dự phòng
 - UPS, nguồn điện dự phòng
 - Firewall, IDS/IPS chống DoS/DDoS

Các mối đe dọa an ninh, biện pháp kiểm soát và các yêu cầu (tt)



Yêu cầu an ninh (Security Requirements)

- ❑ Tùy môi trường và tổ chức, yêu cầu về Confidentiality – Integrity – Availability có thể khác nhau
- ❑ Giải pháp đưa ra cần phải đáp ứng được trong thời điểm hiện tại và các lần kiểm tra định kỳ kế tiếp
- ❑ Thường định nghĩa trong chính sách bảo mật & vận hành của tổ chức như:
 - Xác thực mạnh (multi-factor authentication)
 - Kiểm thử, rà soát bảo mật định kỳ
 - Đảm bảo khôi phục sau thảm họa (Disaster Recovery, Business Continuity)

Ngành nghề	Ưu tiên số 1	Ưu tiên số 2	Ưu tiên số 3
Ngân hàng	Confidentiality Bảo vệ thông tin tài chính và cá nhân của khách hàng khỏi rò rỉ	Integrity Đảm bảo giao dịch và số dư tài khoản chính xác, không bị thay đổi	Availability Cung cấp dịch vụ liên tục để khách hàng có thể truy cập tài khoản mọi lúc
Y tế	Availability Đảm bảo nhân viên y tế có thể truy cập ngay lập tức hồ sơ bệnh án để cứu người	Confidentiality Bảo vệ thông tin sức khỏe cá nhân (PHI) của bệnh nhân theo luật định	Integrity Giữ cho dữ liệu bệnh án chính xác để chẩn đoán và điều trị đúng
Thương mại điện tử	Availability Đảm bảo trang web luôn hoạt động để khách hàng có thể mua sắm	Integrity Đảm bảo giá cả và thông tin sản phẩm chính xác	Confidentaility Bảo vệ thông tin thanh toán của khách hàng để duy trì lòng tin

Bảo mật cơ sở dữ liệu (Database Security)



- ❑ Tương tự bảo mật thông tin, dựa trên C.I.A
- ❑ Liên quan chính đến dữ liệu ở trạng thái tĩnh (data at rest), đang lưu trữ trên thiết bị
- ❑ Tập trung vào việc triển khai công cụ, biện pháp nhằm đảm bảo và duy trì an toàn cho cơ sở dữ liệu.
- ❑ Cùng mục tiêu với bảo mật thông tin nhưng trong phạm vi môi trường CSDL
 - Lựa chọn các biện pháp bảo mật ở cấp CSDL
 - Thiết kế, triển khai, cấu hình các biện pháp phù hợp hệ thống CSDL

Bảo mật cơ sở dữ liệu (tt)



Đảm bảo tính bí mật (Confidentiality)

- ❑ Phân quyền truy cập (Privileges): triển khai kiểm soát truy cập (Access Control)
- ❑ Mã hóa dữ liệu (Encryption): file, ổ đĩa, CSDL
- ❑ Ẩn danh dữ liệu (Data anonymization)



Bảo mật cơ sở dữ liệu (tt)



Đảm bảo tính toàn vẹn (Integrity)

- ❑ Hash/Checksum để phát hiện thay đổi
- ❑ Audit log để theo dõi truy cập dữ liệu
- ❑ Cơ chế đồng bộ để giữ dữ liệu nhất quán
- ❑ Có 4 loại toàn vẹn trong môi trường CSDL
 - Toàn vẹn thực thể (Entity Integrity)
 - Toàn vẹn miền giá trị (Domain Integrity)
 - Toàn vẹn tham chiếu (Referential Integrity)
 - Toàn vẹn nghiệp vụ (Business Rule/User-defined Integrity)

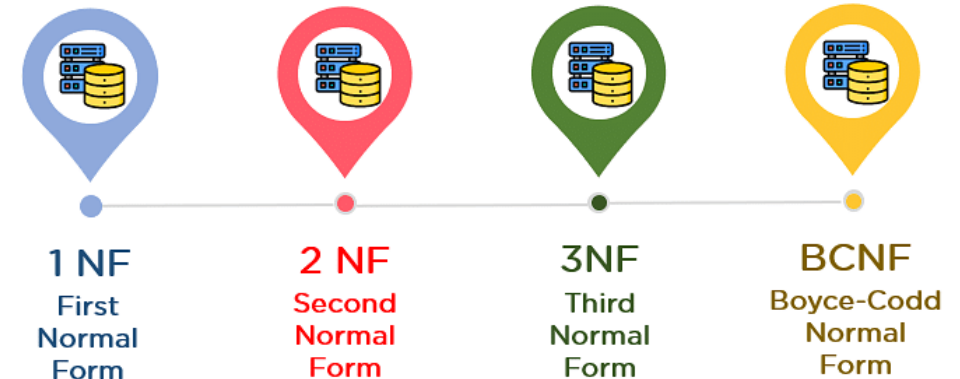
Bảo mật cơ sở dữ liệu (tt)



Đảm bảo tính toàn vẹn (Integrity)

▣ Thiết kế và chuẩn hóa CSDL (Normalization)

- Giúp duy trì Integrity lâu dài
 - 1NF: dữ liệu nguyên tử
 - 2NF: thuộc tính phụ thuộc toàn bộ khóa
 - 3NF: không có phụ thuộc bắc cầu.
 - Ràng buộc: PK, FK, Unique, Check, Not Null



Bảo mật cơ sở dữ liệu (tt)



Đảm bảo tính khả dụng (Availability)

- ❑ Sao lưu và phục hồi dữ liệu (Backup & Restore)
- ❑ Sử dụng phần cứng dự phòng (RAID, Multiple Database Servers)
- ❑ Giải pháp phục hồi sau thảm họa (Disaster Recovery)
- ❑ Kiểm soát khi thiết kế ứng dụng truy xuất dữ liệu
 - Thiết kế, triển khai theo quy trình an toàn
 - Kiểm tra, rà soát mã nguồn
 - Áp dụng các biện pháp an toàn trong mã nguồn khi truy xuất

